

HANDS-ON WORKSHOP • SOC / IR PRACTITIONERS

# Incident Response with Cortex XDR

Driving a real attack chain end-to-end through XDR's investigation surfaces

**SIMULATED ADVERSARY**

**Phantom Master Killchain • 22 abilities • 9 MITRE tactics**

Validated against Cortex XDR cases 1794 + 1795 — 140+ alerts across 22 techniques

# What you'll walk out with

Five concrete capabilities you'll use on a real attack chain — not slides about features

---

01

## Trace an alert to its root cause

Use the causality view to follow a process tree from a single Cortex alert back to its initial-access ancestor — Spearphishing Attachment in our case.

02

## Hunt across the data plane with XQL

Write XQL queries that pivot off an IOC from the causality view and find sibling activity the alerts didn't surface — 800+ catalogued fields, cross-data-source.

03

## Drive a case through the new 5.0 workspace

Triage, prioritize, assign, document, and close a multi-stage incident. Use the AI Case Investigation agent to summarize signals + recommend next steps.

04

## Contain a compromised host live

Isolate the endpoint, block the file hash, open Live Terminal, terminate the process tree, quarantine artifacts — all from the same console.

05

## Read MITRE coverage from telemetry

Map the 22 alerts produced by the simulation onto the ATT&CK matrix and understand which tactics XDR's analytics actually fired on.

# The simulation — Phantom Master Killchain

22 chained abilities that mirror a real ransomware operation — Spearphishing → C2 → Defacement

22

Caldera abilities chained in atomic ordering

9

MITRE ATT&CK tactics covered end-to-end

22

Distinct techniques exercised on the host

140+

Alerts surfaced in Cortex incidents 1794 + 1795

2

Cross-host lateral movement (xdragent ↔ xdragent2)

88.6%

Chain-quality rate validated against XDR analytics

## ATTACK CHAIN PHASES

- 01 Initial Access**  
Phishing macro drops Caldera implant
- 02 Discovery**  
Account / system / share enumeration
- 03 Credential Access**  
LSASS dump + PowerKatz + cached creds
- 04 Priv. Esc. + Persistence**  
Fodhelper UAC bypass + run key + scheduled task
- 05 Defense Evasion**  
Disable Defender + certutil decode
- 06 Lateral Movement**  
SMB + WMI + WinRM to second host
- 07 Collection + Exfil**  
Auto-collection + archive + DNS C2
- 08 Impact + Cleanup**  
Defacement + clear event log

# MITRE ATT&CK coverage map

Each row is a tactic the simulation exercises — each cell is a technique with a real Caldera ability behind it

| TACTIC          | ATT&CK ID | TECHNIQUES EXERCISED                                                                                       |
|-----------------|-----------|------------------------------------------------------------------------------------------------------------|
| Initial Access  | TA0001    | T1566.001 Spearphishing Attachment                                                                         |
| Execution       | TA0002    | T1059.001 PowerShell · T1059.003 Windows Command Shell · T1204 User Execution                              |
| Persistence     | TA0003    | T1136.001 Local Account · T1547.001 Registry Run Key · T1053.005 Scheduled Task · T1574.002 DLL Side-Load  |
| Priv. Esc.      | TA0004    | T1548.002 Fodhelper UAC Bypass                                                                             |
| Defense Evasion | TA0005    | T1562.001 Disable Defender · T1140 Certutil Decode · T1132 Data Encoding                                   |
| Cred. Access    | TA0006    | T1003.001 LSASS Memory · T1003.004 LSA Secrets · T1003.005 Cached Creds · T1555 Credential Manager         |
| Discovery       | TA0007    | T1087.001 Local Account · T1082 System Info · T1018 Remote System · T1135 Network Share · T1518.001 AV/EDR |
| Lateral Mvmt.   | TA0008    | T1021.002 SMB/Admin Shares · T1550 Pass-the-Hash                                                           |
| Collection      | TA0009    | T1119 Automated Collection · T1560 Archive Collected                                                       |
| C2              | TA0011    | T1071.004 DNS · T1197 BITS Jobs                                                                            |
| Exfil.          | TA0010    | T1041 Exfil over C2                                                                                        |
| Impact          | TA0040    | T1491 Defacement · T1070.001 Clear Event Log                                                               |

Every row above produced at least one Cortex XDR alert in incidents 1794 + 1795 — this is verified telemetry, not a wishlist.

# Causality view — find the root cause in one screen

Cortex's process-tree visualization. Every alert traces back to a process node; nodes carry visual verdict.

## WHAT IT DOES

Every Cortex XDR alert has a causality chain — a directed graph of process nodes (the things that ran) and executions (RPC, code injection, file I/O between them) that led to the detection. Nodes carry verdict-colored outlines: red for malicious processes, blue for benign per WildFire. Analysts read the chain end-to-end to identify the root cause.

## WHAT YOU CAN DO ON A NODE

- Investigate further (drill into telemetry)
- Timeline view — chronological events around the node
- Add hash to allow / block list
- Search the file across all endpoints
- Terminate the process — live, on the agent
- Quarantine the file artifact

## LIVE EXAMPLE • INCIDENT 1794

### Causality chain produced by the phishing dropper

#### WINWORD.EXE (masqueraded)

Phishing attachment opens — initial-access trigger

BENIGN



#### cmd.exe /c

Macro spawns shell

BENIGN



#### powershell.exe

Encoded command runs (T1059.001)

MALICIOUS



#### bitsadmin /transfer

BITS job downloads dropper (T1197)

MALICIOUS



#### mars.exe (Caldera implant)

Sandcat beacon comes alive — C2 established

MALICIOUS

# XQL search — hunt beyond what the alerts surfaced

800+ catalogued fields • regex + JSON • merge data across endpoint / network / cloud / identity

## WHEN YOU REACH FOR XQL

- An alert fires — you want to find every OTHER host running the same encoded PowerShell.
- A causality node looks suspicious but didn't trigger analytics — you need to pivot off the parent PID + binary hash.
- Threat-intel drops an IOC at 2am — you need to scope its blast radius across the estate before you wake up the team.
- You're writing a new analytic rule and want to test the query against 30 days of telemetry first.
- Compromise assessment — your customer asks 'are we already in?' for a TTP that fired on a peer.

## EXAMPLE — HUNT THE SIMULATION'S BITS JOB

Find every host where bitsadmin.exe transferred a file in the last 24h:

```
dataset = xdr_data
| filter event_type = ENUM.PROCESS
      and action_process_image_name = "bitsadmin.exe"
      and action_process_image_command_line contains "transfer"
      and _time > to_timestamp("now") - 24h
| comp count() by agent_hostname,
      causality_actor_process_image_name
| sort desc _count
```

## RESULT IN OUR LAB

- xdragent — bitsadmin transferred mars.exe (1 hit, parent powershell.exe)
- xdragent2 — same pattern (1 hit, post-lateral-movement)
- Pivot from this row → causality view of either host → see the FULL ransack chain.

# Case management — the IR workflow you live in

Cortex XDR 5.0 (Feb 2026) rebuilt the case workspace. AI Case Investigation agent + visual context maps.



## WHAT CORTEX XDR 5.0 CHANGED IN THE ANALYST WORKSPACE

| AI Case Summaries                                                                                         | Connection maps                                                                                                  | Case Investigation agent                                                                                                          | Triage status tracking                                                                                                     |
|-----------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Plain-language briefing of complex multi-stage incidents. Analyst reads 3 sentences instead of 40 alerts. | Visualize alerts ↔ assets ↔ users in one graph. See the lateral path the adversary took without writing a query. | Agentic AI suggests next steps, highlights critical evidence, can act with analyst oversight (e.g. host containment, enrichment). | Mark Open / In Progress / Pending Review / Closed. Every status change is audit-trailed; multi-analyst handoffs are clean. |

# Response actions — contain the host without leaving the console

Every action is reversible • every action is audit-logged • every action triggers an agent task you can track

## Isolate Endpoint

### WHAT IT DOES

Halts all network traffic except agent ↔ Cortex XDR. Adversary's C2 channel goes silent immediately. Reversible.

### WHEN

When you've confirmed compromise but haven't finished eradication.

## Live Terminal

### WHAT IT DOES

Remote shell on the host. Use it to inspect filesystem, kill processes, dump memory, copy artifacts — without sending anyone to physically touch the machine.

### WHEN

When you need surgical action that no policy / button covers.

## Block File Hash

### WHAT IT DOES

Add SHA256 to the global block list. Cortex agents refuse to execute the binary next time it appears. Independent of isolation.

### WHEN

After you've confirmed a hash is malicious — prevents recurrence across the estate.

## Terminate Process

### WHAT IT DOES

Kill the running process tree on a specific endpoint, from the causality view. Doesn't wait for the agent's policy to catch it.

### WHEN

When you've found a malicious node and need it gone now.

## Quarantine File

### WHAT IT DOES

Move the malicious artifact to a protected location. File can be restored if it turns out to be FP, or sent to forensics for analysis.

### WHEN

After process termination, to neutralize the artifact on disk.

## Search File on All Endpoints

### WHAT IT DOES

Right-click the hash in causality view → 'Search'. Returns every host where the file currently exists or recently ran.

### WHEN

Lateral-spread assessment in seconds, not hours.



# Hands-on — drive incident 1794 from open to closed

You'll work in pairs. 30 minutes. You have the actual telemetry on the lab tenant.

|               |                    |                                                                                                                                                          |
|---------------|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| 00:00 – 00:05 | Find the alert     | In the Cortex tenant, find incident 1794 (severity high). Note the top-level fired analytics rule.                                                       |
| 00:05 – 00:10 | Read the causality | Open the alert's causality view. Walk from the WildFire-verdict malicious node back to the initial-access process. Identify the root cause.              |
| 00:10 – 00:18 | Pivot to XQL       | From a node hash in the chain, write an XQL query to find every other host that ran the same binary in the last 7 days. Take a screenshot of the result. |
| 00:18 – 00:23 | Open the case      | Set triage status to 'In Progress', assign to yourself, add a 1-paragraph case summary in your own words. (AI summary is fine to compare against.)       |
| 00:23 – 00:28 | Contain the host   | Isolate the endpoint. Block the malicious hash globally. Terminate the process tree from the causality view. Quarantine the artifact on disk.            |
| 00:28 – 00:30 | Close out          | Set triage status to 'Resolved'. Document what you'd do differently in production (this is a lab — what's missing or risky here?).                       |

# What you should walk out remembering

If everything else fades, hold on to these five.

---

1

**The causality view is the spine of every investigation.**

Every alert in Cortex XDR has a process tree behind it. If you don't read that tree, you're triaging on labels.

2

**XQL is your second screen.**

Causality tells you the story; XQL tells you the blast radius. Use both. 800+ fields, cross-data-source. Save your useful queries.

3

**The new 5.0 workspace is collaborative on purpose.**

Open → Triage → Investigate → Respond → Close. Multi-analyst handoffs are first-class. The AI agent is a force multiplier, not a substitute for judgment.

4

**Response is reversible — but only if you act.**

Isolate freely. Block hashes freely. Both undo cleanly if you were wrong. Hesitation costs more than over-containment.

5

**Treat MITRE coverage as evidence, not aspiration.**

The simulation maps to 9 tactics + 22 techniques because it actually fires alerts on each. If your stack doesn't fire on a tactic, it's not covered — vendor claims notwithstanding.